

Laboratório de SOC integrado

Fase 5 — Dashboards e validação por simulação de incidentes

Campo	Valor
Autor	Kauan Trinchetti
Fase	5 de 5 — Dashboards e validação
Escopo	Painéis operacionais nas três ferramentas e simulação de incidentes para validar detecção, resposta e registro
Volume gerado	1.149 eventos no período, 2 de nível 12
Ambiente	VM Ubuntu Server 24.04 · 5 GB RAM · Docker Engine
Status	Concluída

1. Objetivo

Encerrar o laboratório com duas entregas complementares: painéis operacionais que respondam a perguntas concretas de operação, e a validação de todo o encadeamento — detecção, resposta e registro — por meio de incidentes simulados em endpoints reais.

O princípio adotado na construção dos painéis: cada gráfico responde a uma pergunta que um operador ou gestor faria. Painel que não responde a uma pergunta é ruído visual.

2. Simulação de incidentes

Foram executados cenários cobrindo as principais táticas de um comprometimento, sempre contra os próprios endpoints do laboratório e a partir da rede interna.

Cenário	Técnica MITRE	Resultado observado
Força bruta em SSH	T1110.001	Detecção e bloqueio automático da origem
Escalação de privilégio (Windows)	T1484	Evento nível 12 com detalhe forense completo
Adulteração de arquivo (FIM)	T1565.001	Chamado com diferença de conteúdo e hashes
Limpeza do log de segurança	T1070.001	Evento de anti-forense registrado
Indisponibilidade e capacidade	—	Detecção pelo Zabbix, com abertura de chamado

2.1 Força bruta e resposta ativa

O ataque foi conduzido contra o serviço SSH da VM. A partir da terceira tentativa, a resposta do servidor mudou de recusa de credencial para ausência de resposta na conexão. A causa não foi de rede: o módulo de resposta ativa do Wazuh inseriu, no firewall do host, uma regra de descarte para o endereço de origem, ainda durante o ataque.

```
kauan@lab-server:~/lab-soc/wazuh-docker/single-node$ docker compose exec wazuh.manager tail -f /var/ossec/logs/alerts/alerts.json | grep -E '5710|5712|100011'
{"timestamp":"2026-08-21T13:02:14.867+0000","rule":{"level":5,"description":"sshd: Attempt to login using a non-existent user","id":"5710","mitre":{"id":["T1110.001","T1021.004"],"tactic":["Credential Access","Lateral Movement"],"technique":["Password Guessing","SSH"]},"firedtimes":1,"mail":false,"groups":["syslog","sshd","authentication_failed","invalid_login"],"gdpr":["IV_35.7.d","IV_32.2"],"gpg13":["7.1"],"hipaa":["164.312.b"],"nist_800_53":["AU.14","AC.7","AU.6"],"pci_dss":["10.2.4","10.2.5","10.6.1"],"tsc":["CC6.1","CC6.8","CC7.2","CC7.3"],"agent":{"id":"001","name":"srv-linux","ip":"192.168.0.50"},"manager":{"name":"wazuh.manager"},"id":"1787317334.652082","full_log":"Aug 21 13:02:13 lab-server sshd[11131]: Invalid user admin from 192.168.0.201 port 16205","predecoder":{"program_name":"sshd","timestamp":"Aug 21 13:02:13","hostname":"lab-server"},"decoder":{"parent":"sshd","name":"sshd"},"data":{"srcip":"192.168.0.201","srcport":"16205","srcuser":"admin"},"location":"journald"}
{"timestamp":"2026-08-21T13:02:16.889+0000","rule":{"level":3,"description":"Host Blocked by firewall-drop Active Response","id":"651","firedtimes":1,"mail":false,"groups":["ossec","active_response"],"pci_dss":["11.4"],"gpg13":["4.13"],"gdpr":["IV_35.7.d"],"nist_800_53":["SI.4"],"tsc":["CC6.1","CC6.8","CC7.2","CC7.3","CC7.4"],"agent":{"id":"001","name":"srv-linux","ip":"192.168.0.50"},"manager":{"name":"wazuh.manager"},"id":"1787317336.653111","full_log":"2026/08/21 13:02:15 active-response/bin/firewall-drop: {"version":"1","origin":{"name":"node01"},"module":"wazuh-execd"},"command":{"add","parameters":{"extra_args":[]},"alert":{"timestamp":"2026-08-21T13:02:14.867+0000","rule":{"level":5,"description":"sshd: Attempt to login using a non-existent user","id":"5710","mitre":{"id":["T1110.001","T1021.004"],"tactic":["Credential Access","Lateral Movement"],"technique":["Password Guessing","SSH"]},"firedtimes":1,"mail":false,"groups":["syslog","sshd","authentication_failed","invalid_login"],"gdpr":["IV_35.7.d","IV_32.2"],"gpg13":["7.1"],"hipaa":["164.312.b"],"nist_800_53":["AU.14","AC.7","AU.6"],"pci_dss":["10.2.4","10.2.5","10.6.1"],"tsc":["CC6.1","CC6.8","CC7.2","CC7.3"],"agent":{"id":"001","name":"srv-linux","ip":"192.168.0.50"},"manager":{"name":"wazuh.manager"},"id":"1787317334.652082"},"full_log":"Aug 21 13:02:13 lab-server sshd[11131]: Invalid user admin from 192.168.0.201 port 16205"},"predecoder":{"program_name":"sshd","timestamp":"Aug 21 13:02:13","hostname":"lab-server"},"decoder":{"parent":"sshd","name":"sshd"},"data":{"srcip":"192.168.0.201","srcport":"16205","srcuser":"admin"},"location":"journald"},"program":"active-response/bin/firewall-drop"},"decoder":{"parent":"ar_log_json","name":"ar_log_json"},"data":{"srcip":"192.168.0.201","version":"1","origin":{"name":"node01"},"module":"wazuh-execd"},"command":{"add","parameters":{"extra_args":[]},"alert":{"timestamp":"2026-08-21T13:02:14.867+0000","rule":{"level":5,"description":"sshd: Attempt to login using a non-existent user","id":"5710","mitre":{"id":["T1110.001","T1021.004"],"tactic":["Credential Access","Lateral Movement"],"technique":["Password Guessing","SSH"]},"firedtimes":1,"mail":false,"groups":["syslog","sshd","authentication_failed","invalid_login"],"gdpr":["IV_35.7.d","IV_32.2"],"gpg13":["7.1"],"hipaa":["164.312.b"],"nist_800_53":["AU.14","AC.7","AU.6"],"pci_dss":["10.2.4","10.2.5","10.6.1"],"tsc":["CC6.1","CC6.8","CC7.2","CC7.3"],"agent":{"id":"001","name":"srv-linux","ip":"192.168.0.50"},"manager":{"name":"wazuh.manager"},"id":"1787317334.652082"},"full_log":"Aug 21 13:02:13 lab-server sshd[11131]: Invalid user admin from 192.168.0.201 port 16205"},"predecoder":{"program_name":"sshd","timestamp":"Aug 21 13:02:13","hostname":"lab-server"},"decoder":{"parent":"sshd","name":"sshd"},"data":{"srcip":"192.168.0.201","srcport":"16205","srcuser":"admin"},"location":"journald"},"program":"active-response/bin/firewall-drop"},"location":"/var/ossec/logs/active-responses.log"}

```

Figura 1 — Registro do bloqueio automático pelo firewall-drop

```
PS C:\Users\ti> 1..8 | ForEach-Object {
    >> Write-Host "tentativa $_"
    >> ssh -o StrictHostKeyChecking=no -o ConnectTimeout=3 -o PreferredAuthentications=password -o Pub
keyAuthentication=no admin@192.168.0.50 exit
    >> }
tentativa 1
admin@192.168.0.50's password:
Permission denied, please try again.
admin@192.168.0.50's password:
ssh_dispatch_run_fatal: Connection to 192.168.0.50 port 22: Connection timed out
tentativa 2
ssh: connect to host 192.168.0.50 port 22: Connection timed out
tentativa 3
ssh: connect to host 192.168.0.50 port 22: Connection timed out
tentativa 4
ssh: connect to host 192.168.0.50 port 22: Connection timed out
tentativa 5
ssh: connect to host 192.168.0.50 port 22: Connection timed out
tentativa 6
ssh: connect to host 192.168.0.50 port 22: Connection timed out
tentativa 7
ssh: connect to host 192.168.0.50 port 22: Connection timed out
tentativa 8
ssh: connect to host 192.168.0.50 port 22: Connection timed out
PS C:\Users\ti> fgfg
fgfg: O termo 'fgfg' não é reconhecido como nome de cmdlet, função, arquivo de script ou programa
operável. Verifique a grafia do nome ou, se um caminho tiver sido incluído, veja se o caminho está
correto e tente novamente.
No linha:1 caractere:1
+ fgfg
+ ~~~~~
+ CategoryInfo          : ObjectNotFound: (fgfg:String) [], CommandNotFoundException
+ FullyQualifiedErrorId : CommandNotFoundException

PS C:\Users\ti> d
d: O termo 'd' não é reconhecido como nome de cmdlet, função, arquivo de script ou programa
operável. Verifique a grafia do nome ou, se um caminho tiver sido incluído, veja se o caminho está
correto e tente novamente.
No linha:1 caractere:1
+ d
+ ~
+ CategoryInfo          : ObjectNotFound: (d:String) [], CommandNotFoundException
+ FullyQualifiedErrorId : CommandNotFoundException

PS C:\Users\ti>
PS C:\Users\ti>
PS C:\Users\ti> ssh kauan@192.168.0.50
ssh: connect to host 192.168.0.50 port 22: Connection timed out

```

Figura 2 — Do lado do atacante: a recusa de credencial dá lugar ao esgotamento de conexão

3. Painéis operacionais

3.1 Wazuh — visão de segurança

O painel principal destaca, entre 1.149 eventos do período, os 2 de nível 12 — os incidentes que exigem ação. É a métrica que separa sinal de ruído.

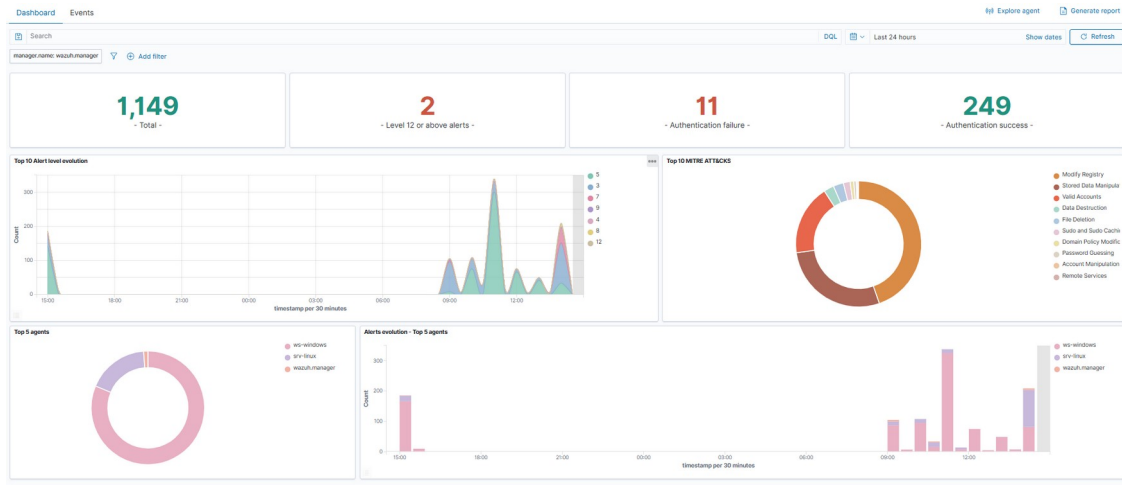


Figura 5 — Panorama de segurança: total de eventos, incidentes graves e autenticações

O painel de MITRE ATT&CK organiza os eventos por tática e técnica, na linguagem padrão de operações de defesa.

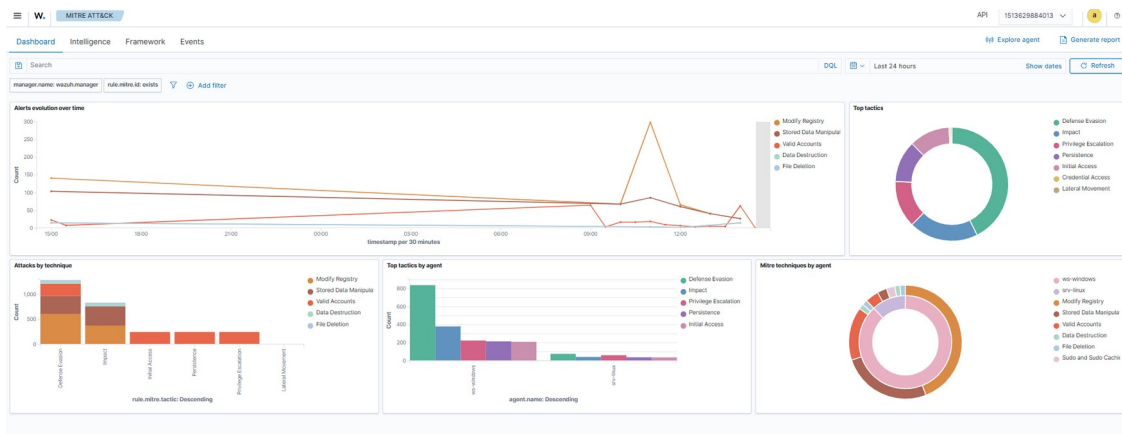


Figura 6 — Eventos mapeados ao framework MITRE ATT&CK

A detecção de vulnerabilidades cruza os pacotes instalados com bases de CVE, priorizando por severidade.

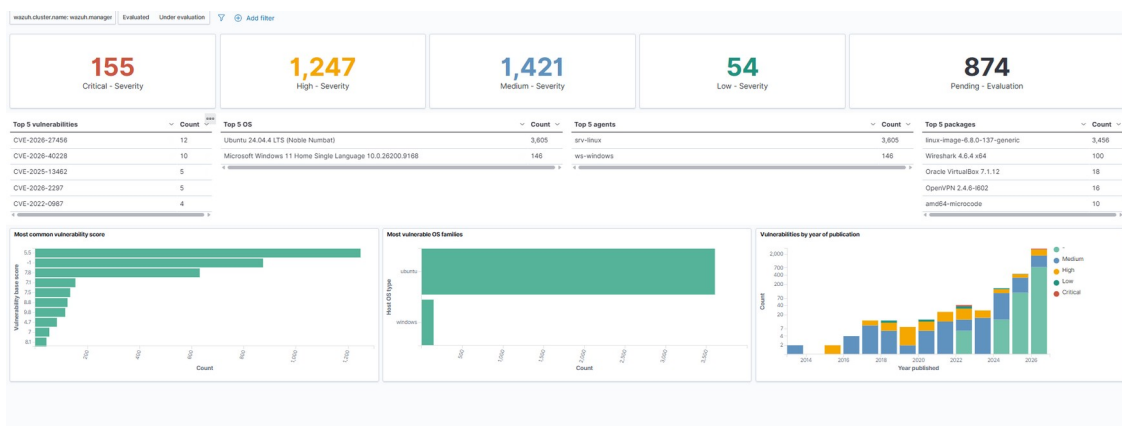


Figura 7 — Vulnerabilidades por severidade nos endpoints

3.2 Zabbix — visão de disponibilidade

O dashboard foi construído com uma pergunta por painel: o que está indisponível, qual recurso está sob pressão e — no painel de registro de ações — quais alertas resultaram em chamado.

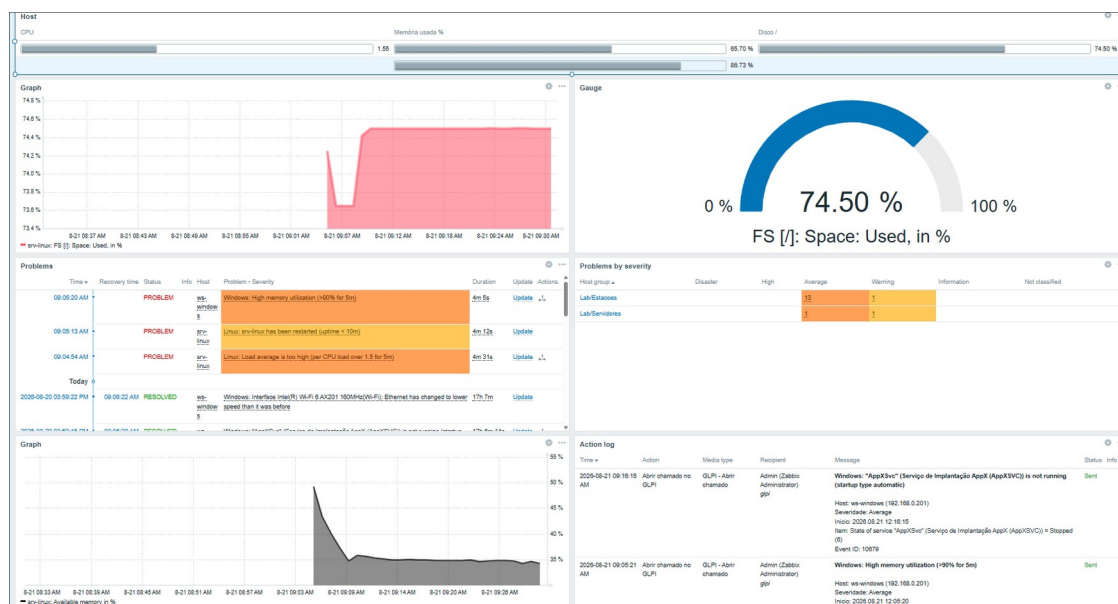


Figura 8 — Painel de NOC com estado dos hosts, capacidade e registro de ações

3.3 GLPI — convergência no service desk

As duas ferramentas alimentam a mesma fila de atendimento, com separação por categoria conforme a natureza do evento e priorização derivada da severidade de origem.

☐	165	[ZABBIX][High] [LAB] Disco / com pouco espaço em srv-linux	New	2026-08-21 14:23	2026-08-21 14:23	High
☐	131	[WAZUH][N5] srv-linux - File added to the system.	New	2026-08-21 14:20	2026-08-21 14:20	Low
☐	128	[WAZUH][N7] srv-linux - Integrity checksum changed.	New	2026-08-21 14:20	2026-08-21 14:20	Low

Figura 9 — Incidentes de segurança e de infraestrutura na mesma fila

4. Achado: amplificação de chamados no FIM

A criação de uma conta de usuário no Linux alterou, em uma única operação, diversos arquivos do diretório de configuração do sistema. Cada arquivo gerou um evento de integridade independente, e cada evento resultou em um chamado — aproximadamente quarenta chamados a partir de uma única ação administrativa.

O contraste com o cenário de força bruta é instrutivo. Naquele caso, a regra de correlação já agregava múltiplas tentativas em um único incidente, e a integração gerava um chamado por incidente. O monitoramento de integridade, por não correlacionar, permite que uma regra legítima disparando em massa inunde o service desk.

A conclusão é que filtrar a integração por identificador de regra é condição necessária, mas não suficiente. Para regras que podem disparar em volume, é preciso agrupar por recurso e janela de tempo antes de gerar o chamado. Fadiga de alerta é um problema de engenharia de detecção, não de visualização.

5. Encadeamento validado

Os cenários confirmaram o funcionamento do ciclo completo pretendido pelo laboratório:

- Detecção: as regras identificam e classificam o evento, incluindo regra de correlação própria
- Resposta: a resposta ativa bloqueia a origem de um ataque em andamento
- Registro: o evento crítico é convertido em chamado com categoria, prioridade e evidência
- Disponibilidade: o Zabbix cobre a camada de infraestrutura, com o mesmo destino de registro
- Tratativa: o chamado pode ser conduzido do registro automático ao encerramento com ação preventiva

6. Conclusão do laboratório

O laboratório entregou um centro de operações funcional e integrado, com detecção, resposta automatizada, monitoramento de disponibilidade e registro centralizado, executado integralmente em uma máquina virtual de 5 GB de memória e a custo zero de licenciamento.

A principal lição não é de instalação. As ferramentas de código aberto envolvidas são bem documentadas e relativamente diretas de implantar. O trabalho de fato está em decidir o que constitui um incidente, o que é ruído operacional, e onde a resposta precisa ser automática — critérios que se constroem observando o ambiente, não copiando um tutorial.

As dificuldades registradas ao longo das cinco fases — dimensionamento de disco, consumo sem limite de módulos, permissões de execução, correlação de eventos, amplificação de chamados — são representativas dos problemas reais de operação de um SOC, e sua documentação constitui parte central do valor deste trabalho.

7. Evolução futura

Item	Descrição
Correlação no FIM	Agrupar eventos de integridade por recurso e janela antes de gerar chamado
Requerente automático	Vincular a conta de serviço como requerente dos chamados automatizados

Item	Descrição
Retenção de dados	Definir política de expurgo de índices e limite de log dos containers
Telemetria adicional	Incorporar Sysmon no Windows e testes do Atomic Red Team
Enriquecimento	Integração com base de reputação de IP para alertas de origem externa